

SECURING THE GENERATIVE ENTERPRISE: The Shadow AI Eradication & Governance Blueprint

**INVESTIGATION IN PROGRESS:
SHADOW AI IDENTIFICATION**

**GOVERNANCE FRAMEWORK
DEVELOPMENT**

**RISK ASSESSMENT
FILES**

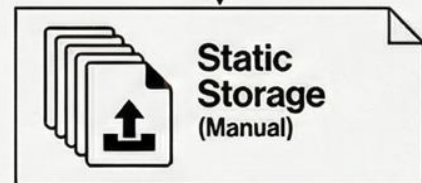
**Starring: Investigation, Governance,
Compliance, Security**

Author : Anand AA

<https://www.linkedin.com/in/piratesshield/>

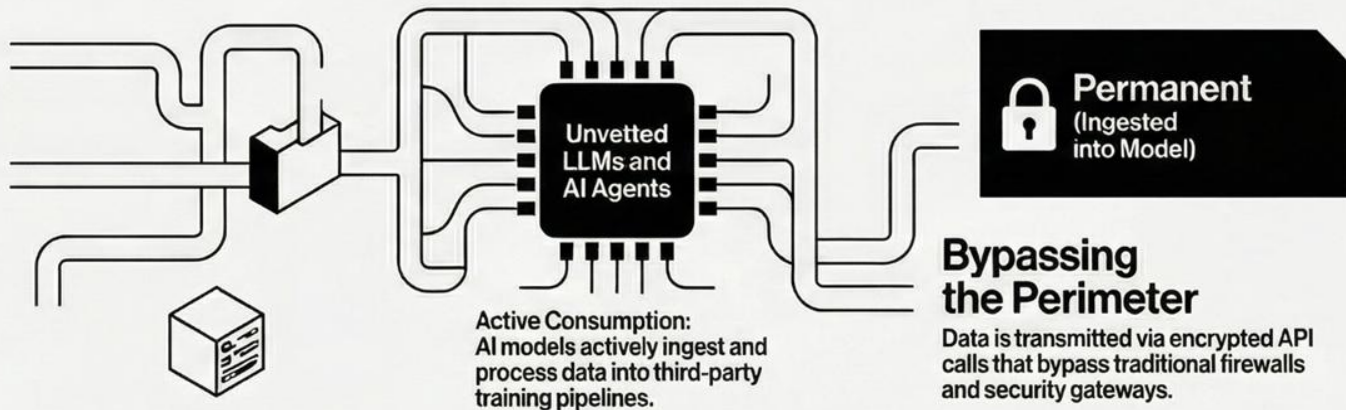
The Velocity of Risk: Understanding Shadow AI in 2026

LEGACY SHADOW IT (MANUAL STORAGE)

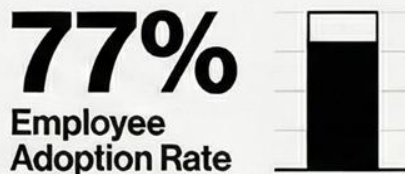


From Manual Storage to Machine Speed:
Legacy Shadow IT required manual uploads; Shadow AI operates natively within daily workflows via prompts.

SHADOW AI (ACTIVE INGESTION & PERMANENCE)



2026 TELEMETRY AND EXPOSURE



Most data sharing occurs outside enterprise visibility via public web interfaces and personal accounts.

The High-Stakes Data Data Mule

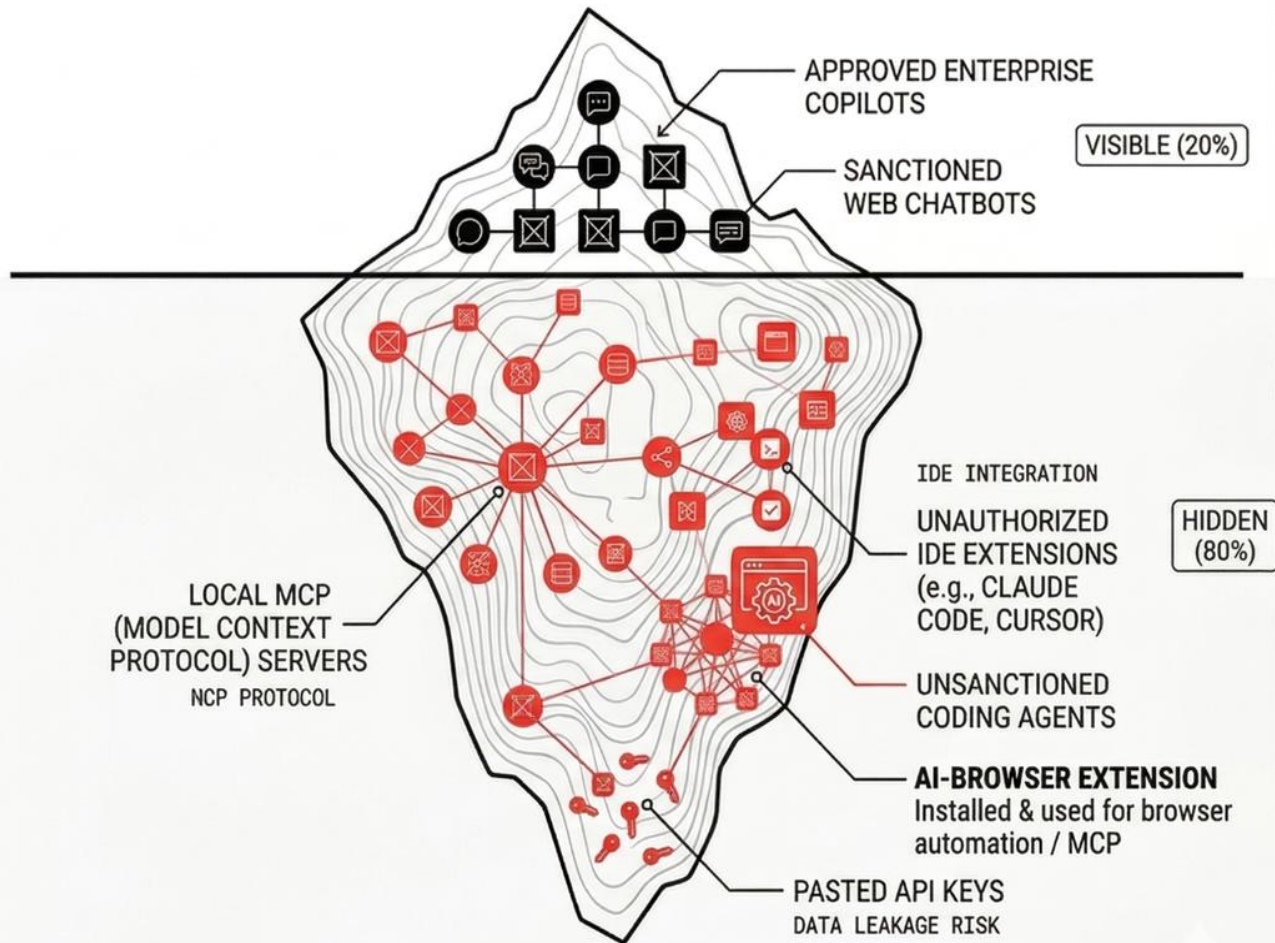
Employees frequently paste proprietary code, financial projections, and customer PII into unvetted tools.



TRADITIONAL IT VISIBILITY FAILS IN THE AGENTIC ERA

The Visibility Gap: Standard SaaS management detects logins, but misses the deeper, AI-native behaviors happening at the IDE and API levels.

The Enterprise Mandate: You cannot govern what you cannot see. Protecting the enterprise requires visibility that penetrates the code and protocol layers.



THE DEEP WEB OF AI AGENTS & INTEGRATIONS

The Shadow AI Blast Radius: Real-World Fallout & Regulatory Risks

Case Study: The Samsung Source Code Leak



Three leaks in 20 days.
Samsung suffered multiple distinct data breaches shortly after lifting its internal generative AI ban.



Proprietary code absorbed into public LLMs.
Engineers used ChatGPT to debug source code and summarize confidential internal meeting notes.



Irreversible Intellectual Property loss.
Consumer AI terms of service default to utilizing user inputs for model training.

The Indian Regulatory Blast Radius



₹250 Crore DPDPA penalties.
Unauthorized processing of PII through unvetted AI pipelines violates core data fiduciary mandates.



The 6-hour CERT-In reporting trap.
Mandatory incident reporting is impossible for Shadow AI due to a lack of logs.



Guaranteed compliance failure.
Without centralized logging, forensic attribution during a breach is technically impossible.

Indian Regulatory Blast Radius: Consequences of Non-Compliance

Regulation	Core Mandated Requirement	Maximum Penalty/Consequence
DPDPA (2023)	Verifiable consent & PII protection	Up to ₹250 crore per contravention
CERT-In	6-hour incident reporting window	Criminal prosecution & systemic fines
RBI PA Directions	Escrow integrity & localized storage	Suspension or revocation of operating license

THE VISIBILITY CRISIS: WHY LEGACY SECURITY FAILS SHADOW AI

LEGACY ASSUMPTIONS: STATIC INFRASTRUCTURE



CENTRALIZED CHOKEPOINTS

Traditional security tools rely on the outdated assumption that data passes through a centralized network chokepoint.

FAILURE OF STATIC INSPECTION



CASB and SSPM tools cannot inspect context-heavy, browser-based interactions.



FRAGMENTED API REQUESTS

High-speed, encrypted API calls to LLM providers prevent legacy tools from understanding interaction context.

MODERN AI REALITY: THE 90% BLIND SPOT

90%

OF AI INTERACTIONS
ARE UNMONITORED



90% OF AI INTERACTIONS ARE UNMONITORED

Modern GenAI usage effectively disappears from the view of traditional enterprise security stacks.



GenAI data processing occurs locally within the browser's Document Object Model, bypassing traditional network filters.



THE ENCRYPTION BARRIER

Legacy CASBs are unable to decrypt and inspect the specific API requests used by AI extensions.

COMPARISON: LEGACY vs. GENAI REALITY

SECURITY FEATURE	LEGACY INFRASTRUCTURE (CASB/SSPM)	GENERATIVE AI REALITY
TRAFFIC PATH	Centralized Network Chokepoint	Local Browser Context (DOM)
INSPECTION TYPE	Static/Centralized Inspection	High-Speed, Encrypted API Calls
VISIBILITY LEVEL	100% (Legacy SaaS)	<10% (Modern GenAI)



Business failure in a
high-competency
market

Employee
productivity loss

User
Friction

CISO / CTO

Blanket-Ban on AI apps



**Everyone follows
the rules // Me:
Finds a loophole**



AI Governance: Securing the Enterprise Frontier

The Mandate: Acceptable Use Policy (AUP)

ZERO TOLERANCE FOR PERSONAL ACCOUNTS



Establish a Board-ratified mandate banning personal AI account usage on all corporate devices.

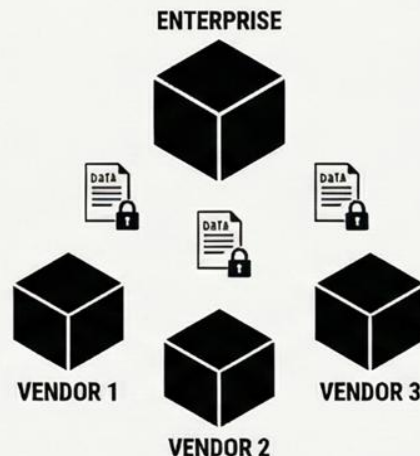
POLICY-DRIVEN TECHNICAL CONTROLS



Technical restrictions are legally meaningless without the foundation of a formal, ratified AUP.

The Control: Advanced Third-Party Risk Management (TPRM)

MSA FLOW-DOWN CLAUSES



Update all vendor Master Service Agreements to include strict, legally binding AI data-handling clauses.

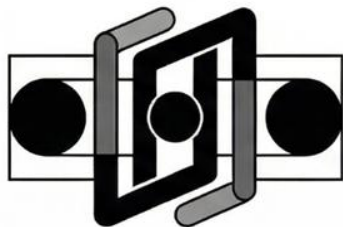
MANDATORY AI SBOM CERTIFICATION



Vendors must provide an AI Software Bill of Materials to certify data exclusion from training.

AI Security Architecture: Technical Orchestration & Network Chokepoints

THE MULTI-LAYERED CHOKEPOINTS



Secure Web Gateway (SWG) Inline Inspection

Establishes primary network chokepoints to decrypt SSL traffic and classify AI prompts in real-time.



Multi-Channel Data Loss Prevention (DLP)

Deploys context-aware Network and Email DLP to secure sensitive data-in-motion.



Endpoint Guardrails & Local Remediation

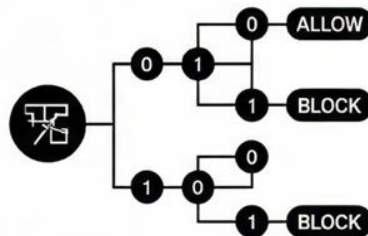
Monitors clipboards and automatically deletes sensitive PII or confidential data stored on user machines.

INTELLIGENCE & AUTOMATED RESPONSE



Dynamic User & Device Risk Scoring

Quantifies threats via 0-100 user behavior metrics and real-time Zero Trust Assessment (ZTA).



Real-Time Automated Decision Engine

Instantly allows or blocks interactions based on real-time classification and risk-based guardrails.



AI-Powered SOC Escalation

Triggers SIEM alerts and isolates interactions when users repeatedly attempt to bypass security guardrails.

INTERNAL ATTACK SURFACE MANAGEMENT (IASM): THE IDENTITY-GOVERNED FRONTIER

As the traditional network perimeter dissolves, organizations must transition to IASM, where identity is the new security boundary, requiring unified governance over human users, machine entities, and autonomous AI agents.

UNIFIED IDENTITY ARCHITECTURE		ADAPTIVE POSTURE AND DATA LIFECYCLE			
	IAM FOR THE AGENTIC ERA Treat AI agents as primary identity actors with distinct lifecycles and permission boundaries.		ENDPOINT ZERO TRUST SCORING Dynamic risk scores calculated from real-time device vulnerabilities, activity patterns, and compliance.		
		PAM FOR MACHINE ENTITIES Non-human identities (NHIs) represent the fastest-growing attack surface requiring privileged access rigor.		UEBA FOR BEHAVIORAL INTEGRITY Continuous monitoring (UEBA) detects anomalies in user and entity interactions across cloud environments.	
		UNIVERSAL HUMAN AUTHENTICATION Enforce FIDO2 and SSO as the mandatory backbone for all sanctioned internal applications.		INTENT-BASED DATA LIFECYCLE Securing data through DSPM by classifying assets based on intent rather than static labels.	
	COMPARISON OF GOVERNANCE PILLARS				
	PILLAR		CORE CONTROL MECHANISM	PRIMARY RISK FOCUS	
	Identity		IAM & PAM for AI	Autonomous Agent Escalation	
	Endpoint		Zero Trust Scoring	Vulnerability and Compliance Gaps	
Data	DSPM & Lifecycle	Intent-based Exfiltration			

DATA RIGOR FOR ENTERPRISE AI: THE MEDALLION ARCHITECTURE

Process flow: Moving data through stages of refinement to prevent security risks and ensure authorized, safe AI inference.

THE RISK OF "DARK DATA"

THE INTERNAL AUTHORIZATION GAP

Feeding unclassified, unstructured files into AI creates massive risks for unauthorized internal data access.

EXECUTIVE COMPENSATION EXPOSURE

Without rigor, a junior employee could query an internal AI for the CEO's compensation package.

THE BRONZE LAYER (RAW)

This unstructured, unclassified data must be strictly quarantined from all AI inference engines.

THE PATH TO AI-READY DATA

THE SILVER LAYER (SANITIZED)

Data is pseudonymized and scrubbed of PII to prepare for secure internal processing.

THE GOLD LAYER (AI-READY)

Highly structured semantic data tagged for utilization in enterprise RAG models.

5-LEVEL CLASSIFICATION TAXONOMY

Gold data must be tagged from Level 1 (Public) to Level 5 (Restricted).

How to build Data-Security - Blueprint :
<https://github.com/piratesshield/NullBangalorePresentation/tree/main/13Dec2025>

ERADICATING SHADOW AI: THE IDENTITY-ANCHORED DISCOVERY STRATEGY

A dual-pronged approach combining a human-centric amnesty program with technical telemetry for full visibility and control over unauthorized AI usage.

PHASE 1 — THE HUMAN-CENTRIC AMNESTY PROGRAM

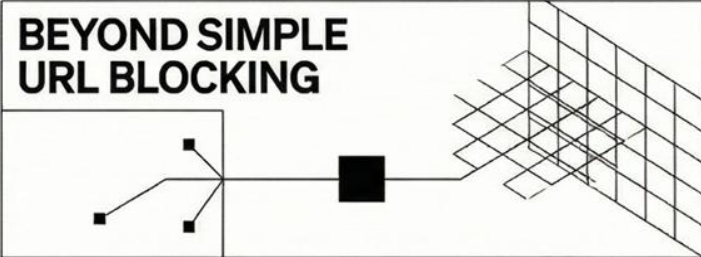
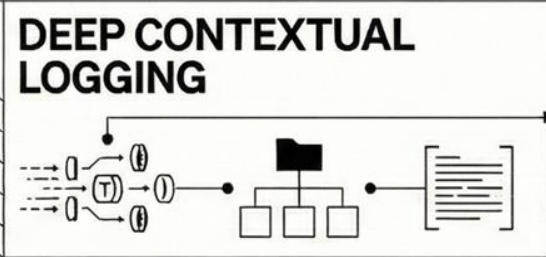
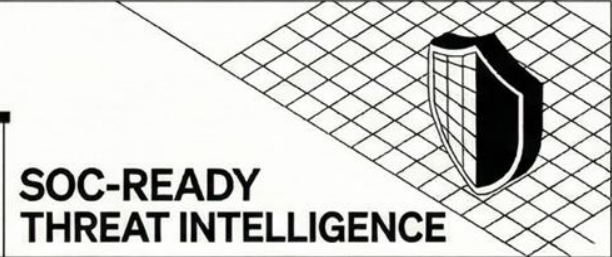
30-Day Shadow IT Amnesty Window

A designated period for employees to declare unvetted AI tools without fear of reprimand.

Surfacing the “Utility Gap”

Identifies why employees bypass sanctioned tools, helping migrate legitimate needs to approved alternatives.

PHASE 2 — THE AI TELEMETRY DASHBOARD

BEYOND SIMPLE URL BLOCKING 	DEEP CONTEXTUAL LOGGING 	SOC-READY THREAT INTELLIGENCE 
Audits SSO logs and integrates edge-capture tools for a forensic view of usage.	Tracks specific departments, token volumes, and the actual text of submitted prompts.	Provides the necessary context to identify insider threats and prevent non-recoverable data breaches.

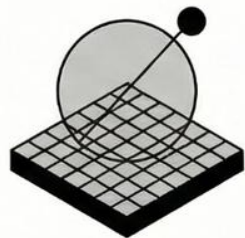
EVOLUTION FROM TRADITIONAL MONITORING

FEATURE	TRADITIONAL MONITORING	AI TELEMETRY DASHBOARD
Visibility	Simple URL/Domain Blocking	Forensic SSO & Edge-Capture
Data Detail	Traffic Volume Only	Prompt Text & Token Counts
Context	Application-Level	Departmental & User-Role Context

AI Maturity & Execution Roadmap: From Vulnerability to Certified Resilience

A structured 24-month journey to eliminate "Shadow AI" and establish a resilient governance framework, moving from initial discovery to sanctioned enablement and strict enforcement, culminating in international certification.

2026 EXECUTION: THE FOUNDATION AND ENFORCEMENT



Q2 2026: Foundation & Discovery

Launch amnesty programs and deploy Secure Web Gateway (SWG) baselines to gain 100% visibility.



Q3 2026: Sanctioned Enablement

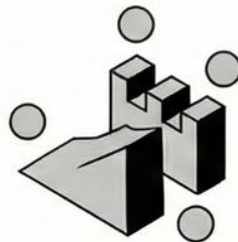
Launch an internal Enterprise AI Hub to route 80% of traffic through sanctioned tools.



Q4 2026: Hard Enforcement

Activate IDE guardrails and strict DLP blocking to reduce shadow instances to near zero.

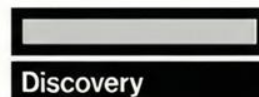
2027: SUSTAINABILITY AND CERTIFICATION



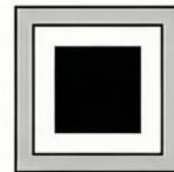
Continuous Red Team Testing

Conduct ongoing adversarial testing of all AI surfaces to maintain security posture.

Success Metrics



100% visibility into
current AI shadow
usage



Zero Data Exfiltration

Maintain rigorous controls to ensure no unauthorized data leaves the corporate perimeter.



80% of generative
traffic routed through
sanctioned tools



ISO 42001 Certification

Pursue and achieve formal external audits to certify organizational AI resilience.



Achieve ISO 42001
Certification



THE END !

Any Questions???

Connect with Me :

